

Fundamentals of Information Systems Security

Chapter 9 Quiz Answer Key

Instructor: Guuleed Maxamuud Aw Abdi

Section A: Multiple Choice (40 points)

1. **A** — A systematic evaluation of a computing environment against security goals
2. **B** — Monitor, Audit, Improve, Secure
3. **A** — A documented minimum level of security configuration
4. **A** — IDS is passive (detects); IPS is active (prevents)
5. **B** — Signature-based detection
6. **A** — An alert triggered for benign activity
7. **B** — A real attack that was missed
8. **A** — Security Information and Event Management
9. **A** — Changing default configurations to make a system more secure
10. **A** — Vulnerability testing identifies weaknesses; penetration testing exploits them

Section B: True/False (20 points)

1. **False** — Unannounced audits provide more accurate results
2. **True** — COBIT is an IT governance framework
3. **True** — SOC reports report on controls at service organizations
4. **False** — Log files are essential for accountability
5. **False** — All systems need hardening
6. **True** — DMZ is a buffer zone between trusted and untrusted networks
7. **False** — Black-box testing has no prior knowledge of the system
8. **True** — White-box testing provides the deepest analysis
9. **True** — Continuous monitoring is essential
10. **False** — Penetration testing can be performed on production with proper planning

Section C: Short Answer (40 points)

1. Four Permission Levels (10 points)

- **Promiscuous:** Everything is allowed. Common in home networks but highly vulnerable
- **Permissive:** Anything not prohibited is okay. Suitable for public-facing websites
- **Prudent:** Reasonable list permitted, all others prohibited. Standard for most businesses
- **Paranoid:** Very few things permitted, all others prohibited and monitored. Necessary for highly secure facilities

2. Signature vs. Anomaly Detection (10 points)

- **Signature-Based:** Compares traffic against known attack patterns (signatures). Effective for known attacks, requires constant updates, cannot detect zero-day attacks
- **Anomaly-Based:** Establishes baseline of "normal" activity; triggers alerts on deviations. Can detect unknown attacks but may have high false positives

3. SIEM and SOAR Benefits (10 points)

- **SIEM:** Collects log data from diverse sources, normalizes it, stores in central database, provides real-time dashboard, enables powerful reporting and analysis
- **SOAR:** Extends SIEM by enabling definition and automation of incident response procedures, helps respond to and manage incidents in structured, efficient manner
- Together: Core of modern Security Operations Center (SOC)

4. Black-Box, White-Box, and Gray-Box Testing (10 points)

- **Black-Box:** No prior knowledge of system; simulates external attacker. Best for realistic external assessment
- **White-Box:** Full knowledge (source code, architecture); deepest analysis. Best for comprehensive internal assessment
- **Gray-Box:** Limited knowledge (user credentials); simulates insider threat. Best for realistic internal assessment